LABORATORIO TÉCNICO · CLOUD SECURITY / DEVSECOPS

AWS DevSecOps Security Lab
Red Team → Blue Team sobre EC2

Instancia devsecops-lab · Evaluación SSH público e IMDSv2 · us-east-1

ESTUDIANTE / PRACTICANTE

Jesús Alejandro Rodríguez Medina

ROL

DevSecOps / Analista de Ciberseguridad Jr.

INSTANCE ID

`i-0953d0d0095a3e13d`

REGIÓN / AZ

`us-east-1 / us-east-1d`

SISTEMA OPERATIVO

`Ubuntu Server 22.04.5 LTS`

TIPO DE INSTANCIA

`t3.micro`

Metodología Red Team → Blue Team | AWS Well-Architected — Security Pillar | CIS Benchmarks (SSH / Cloud)

Código de Documento: REP-ASM-2026-AWS01

• RIESGO GLOBAL: BAJO (SSH e IMDS remediados y validados)

1. Resumen Ejecutivo

Durante el laboratorio de seguridad en AWS se implementó y evaluó una infraestructura controlada destinada a practicar conceptos de Cloud Security, DevSecOps, Red Team y Blue Team sobre una instancia EC2 Ubuntu (**devsecops-lab**). El trabajo se realizó bajo un modelo de **Red Team → evidencia → Blue Team → remediación → validación**.

Se identificaron dos superficies de riesgo principales: **(1)** exposición pública del servicio SSH (TCP/22 permitido desde 0.0.0.0/0) y **(2)** acceso al EC2 Instance Metadata Service (IMDS) sin token, con IMDSv2 configurado inicialmente como *Optional*. Ambos casos quedaron **remediados y validados**: el caso IMDS mediante IMDSv2 Required → HTTP 401, y el caso SSH mediante la restricción del Security Group de 0.0.0.0/0 a la IP administrativa autorizada (/32), confirmando acceso únicamente desde el origen legítimo.

Adicionalmente, durante el monitoreo del laboratorio se analizó un evento de actividad administrativa inicialmente marcado como potencialmente sospechoso, el cual fue clasificado como **falso positivo** tras el análisis — sin evidencia de compromiso, aunque se identificó una deficiencia de procedimiento en la notificación previa al equipo de seguridad.

RIESGO INICIAL GLOBAL	RIESGO FINAL GLOBAL	CASO IMDS	CASO SSH
MEDIO-ALTO	BAJO	COMPLETADO	COMPLETADO

2. Objetivo del Laboratorio

Evaluar la postura de seguridad de una infraestructura AWS pequeña y controlada, simulando situaciones que pueden presentarse en ambientes reales.

- Identificar servicios expuestos y analizar la configuración de red de EC2.
- Revisar la configuración SSH, usuarios, privilegios y mecanismos de autenticación.
- Comprobar controles defensivos existentes (Fail2Ban) y el acceso al servicio IMDS.
- Simular técnicas de acceso remoto de forma controlada y aplicar medidas de Blue Team.
- Validar que las medidas defensivas funcionaran y documentar evidencia técnica y riesgo residual.

3. Alcance e Infraestructura Analizada

Recurso	Valor
EC2	devsecops-lab
Instance ID	i-0953d0d0095a3e13d
Región / AZ	us-east-1 / us-east-1d
OS	Ubuntu 22.04.5 LTS
Instance Type	t3.micro
VPC	vpc-0baa4b75645f6b237 (172.31.0.0/16)

Subnet	subnet-01af7239c9a74725c (172.31.32.0/20)
Security Group	launch-wizard-3
Key Pair	devsecops-key-new
IP privada / pública	172.31.34.81 / 34.235.163.220

El alcance estuvo limitado a recursos propios del laboratorio AWS. No se atacó infraestructura ajena.

4. Arquitectura y Situación Inicial

La instancia EC2 era accesible desde Internet mediante IP pública. El acceso SSH se realizaba con una llave privada local (`devsecops-key-new.pem`). La configuración inicial del Security Group permitía:

```
TCP 22  —  Source: 0.0.0.0/0
```

Cualquier dirección IPv4 en Internet podía intentar establecer una conexión TCP contra el puerto SSH. Esto no implica compromiso automático, pero sí una superficie de ataque pública.

5. Evaluación Inicial de Seguridad

5.1. Descubrimiento del Servicio SSH (Nmap)

```
nmap -Pn -p 22 -sV --reason <IP_PUBLICA>
```

```
22/tcp open ssh
OpenSSH 8.9p1 Ubuntu 3ubuntu0.15
Ubuntu Linux
```

TCP/22 accesible desde Internet, abierto, ejecutando OpenSSH sobre Ubuntu Linux. **Riesgo: exposición pública de SSH**

5.2. Verificación de Conectividad (PowerShell)

```
Test-NetConnection <IP_PUBLICA> -Port 22
```

Resultado: **TcpTestSucceeded : True** — se confirmó accesibilidad externa del servicio.

5.3. Configuración Efectiva de SSH

```
sudo sshd -T | grep -Ei 'permitrootlogin|passwordauthentication|pubkeyauthentication|
kbdinteractiveauthentication|x11forwarding|port|authenticationmethods'
```

```
port 22
permitrootlogin no
pubkeyauthentication yes
passwordauthentication no
kbdinteractiveauthentication no
x11forwarding yes
authenticationmethods any
```

Control	Evaluación
PermitRootLogin = no	Positivo
PasswordAuthentication = no	Positivo
PubkeyAuthentication = yes	Positivo
KbdInteractiveAuthentication = no	Positivo
X11Forwarding = yes	Hardening recomendado

5.4. Servicios Escuchando

```
sudo ss -tulpen
```

Resultado principal: `tcp 0.0.0.0:22 sshd` y `tcp [::]:22 sshd`. SSH fue el principal servicio TCP expuesto externamente.

5.5. Usuarios y Privilegios

```
getent passwd | cut -d: -f1
id devsecops
sudo -l -U devsecops
sudo grep -RniE '^[[:space:]]*%sudo[[:space:]]' /etc/sudoers /etc/sudoers.d/
```

Usuario **devsecops** → grupo `sudo` → `(ALL : ALL) ALL`. Privilegios administrativos completos. No se clasifica automáticamente como vulnerabilidad, pero sí como riesgo de impacto elevado si las credenciales fueran comprometidas:

Compromiso llave SSH → **Acceso devsecops** → **Grupo sudo** → **Compromiso total del sistema**

5.6. Permisos de .ssh

Ruta	Permisos	Evaluación
/home/devsecops	750	OK
/home/devsecops/.ssh	755	Mejorable → 700
/home/devsecops/.ssh/authorized_keys	600	Correcto

6. Caso 1 — Exposición Pública de SSH (Red Team)

Simulación controlada de intento de acceso remoto, para determinar si un atacante externo podía llegar al servicio SSH y qué método de autenticación estaba disponible. Condición inicial: `TCP 22 → 0.0.0.0/0`.

Ataque Controlado

```
ssh -o PreferredAuthentications=password -o PubkeyAuthentication=no usuario-falso@34.235.163.220
```

No se utilizó la llave .pem — intencional, para simular un atacante sin llave privada legítima.

```
usuario-falso@34.235.163.220: Permission denied (publickey).
```

Resultado del ataque Sin compromiso

El servidor fue alcanzable, el usuario falso no pudo autenticarse, SSH no aceptaba contraseña y no se obtuvo sesión ni ejecución de comandos.

Evidencia en Logs

```
sudo grep -Ei 'usuario-falso|Failed|Invalid user|authentication failure' /var/log/auth.log | tail -30
```

Se encontró "Invalid user usuario-falso" y "Connection reset by invalid user usuario-falso". **Precaución forense:** el evento tenía marca temporal anterior y procedía de una IP también asociada a una sesión legítima, por lo que no se atribuyó automáticamente al intento inmediato — distinción importante para un reporte profesional.

Fail2Ban

```
sudo fail2ban-client status
sudo fail2ban-client status sshd
```

```
Jail: sshd
Currently failed: 0 | Total failed: 0 | Currently banned: 0 | Total banned: 0
```

Fail2Ban estaba activo con el jail `sshd`, pero **no** se debe afirmar que "bloqueó el ataque" — la simulación no produjo un bloqueo durante la prueba.

Grado de Situación — Caso SSH

Estado	Detalle
Estado inicial	ALTO — SSH expuesto a Internet, usuario admin con sudo, superficie remota permanente
Controles existentes	Root SSH off · Password off · Pubkey on · authorized_keys 600 · Fail2Ban activo
Resultado del ataque	Sin acceso no autorizado
Riesgo residual (previo al parche)	MEDIO/ALTO mientras SSH continuó expuesto globalmente

Parche Aplicado (Blue Team)

ANTES

- TCP 22
- Source: 0.0.0.0/0
- Accesible desde cualquier IP de Internet

DESPUÉS

- TCP 22
- Source: <IP_ADMINISTRADOR>/32
- Acceso único desde el origen administrativo autorizado

Validación del Parche

```
Test-NetConnection <IP_PUBLICA> -Port 22   (desde IP administrativa)
Test-NetConnection <IP_PUBLICA> -Port 22   (desde IP no autorizada)
```

Resultado: conexión exitosa únicamente desde la IP administrativa autorizada; el resto de orígenes quedó denegado a nivel de Security Group.

Estado al cierre: COMPLETADO — la restricción del Security Group fue aplicada y validada; el servicio SSH dejó de estar expuesto a 0.0.0.0/0.

7. Caso 2 — EC2 Instance Metadata Service (IMDS)

Caso de Cloud Security relacionado con SSRF. Objetivo: determinar si la instancia podía consultar `169.254.169.254` sin autenticación mediante token (IMDSv2).

Situación Inicial

`IMDSv2: Optional` `IAM Role: ninguno`

Sin IAM Role asociado no existían credenciales temporales de Instance Profile que pudieran extraerse — esto redujo considerablemente el impacto potencial del ejercicio.

Prueba Red Team

```
curl -s http://169.254.169.254/latest/meta-data/
```

El servidor respondió con categorías de metadatos (ami-id, hostname, instance-id, local-ipv4, public-keys/, security-groups, etc.) **sin exigir token**. **IMDS accesible sin IMDSv2**

```
curl -s http://169.254.169.254/latest/meta-data/iam/info
```

Respuesta: **404** — consistente con "No IAM Role asociado". Por seguridad, no se intentó obtener credenciales ni extraer información sensible (decisión deliberada).

```
curl -X PUT http://169.254.169.254/latest/api/token -H "X-aws-ec2-metadata-token-ttl-seconds: 60"
```

Se obtuvo un token temporal (60s) para demostrar que IMDSv2 estaba disponible — no se usó para extraer credenciales.

Remediación (Blue Team)

ANTES

- IMDSv2: Optional

DESPUÉS

- IMDSv2: Required
- Resto de configuración sin cambios

Validación del Parche

```
curl -s -o /dev/null -w "HTTP %{http_code}\n" http://169.254.169.254/latest/meta-data/
```

```
HTTP 401
```

IMDSv2 Optional → PATCH → IMDSv2 Required → Consulta sin token → HTTP 401

Estado	Detalle
Antes del parche	MEDIO — exposición de metadata sin exigir IMDSv2
Después del parche	BAJO / CONTROLADO — IMDSv2 obligatorio
Validación	HTTP 401 confirmado
Estado final	COMPLETADO

8. Caso 3 — Evaluación General de Postura de Seguridad

No se trata de un tercer ataque, sino de la evaluación integral de seguridad y hardening realizada antes y alrededor de las pruebas ofensivas.

Controles Positivos Encontrados

Control	Evaluación
PermitRootLogin = no	Correcto
PasswordAuthentication = no	Correcto
PubkeyAuthentication = yes	Correcto
Fail2Ban (jail sshd)	Presente
authorized_keys = 600	Adecuadamente protegido
IMDSv2 Required (post-hardening)	Correcto
Sin IAM Role asociado	Positivo (least privilege)

Hallazgos Adicionales de Hardening

EBS sin cifrado — Hardening / Datos en reposo

Volumen raíz de 8 GiB con `Encrypted: No`. No es una vulnerabilidad remota directa; se recomienda EBS Encryption en ambientes productivos.

Monitoreo detallado deshabilitado — Mejora recomendada

Detailed Monitoring: Disabled. No es una vulnerabilidad directa, pero limita la visibilidad operacional.

X11 Forwarding habilitado — Hardening recomendado

No se encontraron conexiones activas en puertos X11. Se recomienda deshabilitarlo si no se requiere interfaz gráfica remota.

Directorio .ssh en 755 — Hardening menor

El archivo authorized_keys está correctamente protegido (600); el directorio podría endurecerse de 755 a 700.

devsecops con privilegios sudo completos — Riesgo potencial elevado

No se considera vulnerabilidad por sí misma si el acceso administrativo es intencional, pero eleva el impacto ante un eventual compromiso de credenciales.

9. Caso Adicional — Actividad Administrativa Analizada como Falso Positivo

Durante el monitoreo del laboratorio se identificó una actividad asociada a una cuenta con privilegios administrativos que inicialmente fue considerada potencialmente sospechosa. El evento tuvo que analizarse de manera continua para determinar si correspondía a una acción maliciosa o a una actividad legítima.

Hallazgos del Análisis

- La actividad correspondía a una acción legítima realizada por el administrador.
- No se encontraron evidencias suficientes de compromiso, intrusión o ejecución maliciosa.
- No se identificó una escalada de privilegios no autorizada.
- No se detectó extracción de credenciales ni persistencia.
- La actividad fue catalogada como falso positivo desde el punto de vista de seguridad.

Deficiencia de procedimiento identificada — Incumplimiento de protocolo

El administrador no siguió el protocolo establecido para notificar previamente al equipo de seguridad sobre la actividad administrativa. Esto provocó que una actividad legítima apareciera inicialmente como una posible alerta de seguridad, obligando al equipo a realizar un análisis adicional para descartar un incidente.

Clasificación Final

Campo	Resultado
Resultado de seguridad	Falso positivo
Actividad	Legítima / administrativa
Compromiso	No identificado
Problema principal	Incumplimiento del protocolo de notificación/comunicación
Impacto	Generación de una alerta sospechosa y necesidad de investigación adicional

Lección Blue Team

Las actividades administrativas autorizadas deben registrarse y notificarse conforme al procedimiento establecido, para evitar falsos positivos y permitir una correcta correlación de eventos.

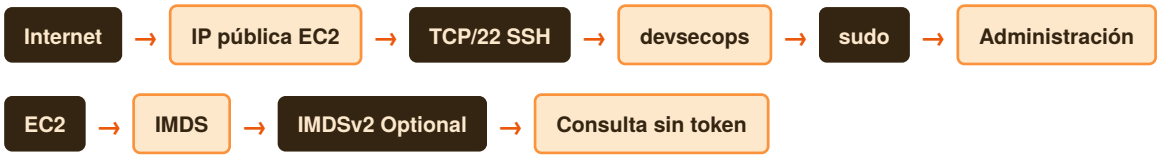
El evento fue finalmente clasificado como falso positivo, debido a que la actividad analizada correspondía a una acción legítima de administración y no se encontraron indicadores de compromiso. No obstante, se identificó una debilidad en el proceso operativo, ya que el administrador no notificó previamente al equipo de seguridad sobre la actividad que iba a realizar. Esta falta de comunicación provocó que una operación legítima fuera inicialmente tratada como potencialmente sospechosa y requiriera un análisis continuo hasta confirmar su legitimidad.

10. Matriz de Riesgos

Hallazgo	Impacto	Probabilidad	Riesgo
SSH expuesto 0.0.0.0/0	Alto	Alta	Alto
Usuario administrativo por SSH	Alto	Media	Medio/Alto
devsecops con sudo	Alto	Media	Medio/Alto
IMDSv2 Optional	Medio/Alto	Media	Medio
EBS sin cifrado	Medio	Baja/Media	Medio
X11 forwarding	Bajo/Medio	Baja	Bajo
.ssh en 755	Bajo	Baja	Bajo
Fail2Ban presente	—	—	Control positivo
Root SSH deshabilitado	—	—	Control positivo
Password SSH deshabilitada	—	—	Control positivo
IMDSv2 Required (post-parche)	—	—	Control positivo
SSH restringido a IP admin /32 (post-parche)	—	—	Control positivo
Actividad admin sin notificación previa	Bajo	Media	Bajo (procedimiento)

11. Evolución de la Postura de Seguridad

Estado Inicial



Estado Después del Blue Team

Internet → Security Group → TCP/22 solo IP admin /32 → SSH (Public Key)

EC2 → IMDS → IMDSv2 Required → Sin token = HTTP 401

12. Estado Final de Actividades

🟢 Completado

- Reconocimiento de EC2 y servicios
- Evaluación y revisión de autenticación SSH
- Revisión de usuarios y privilegios
- Evaluación de Fail2Ban
- Prueba controlada SSH e IMDS
- IMDSv2 Optional → Required + validación HTTP 401
- Restricción SG de SSH a IP admin / 32 aplicada y validada
- Análisis de actividad administrativa (falso positivo confirmado)
- Documentación de evidencias
- Sin extracción de credenciales ni compromiso real

🟡 Pendiente

- Hardening adicional de .ssh (755 → 700) y X11 forwarding
- Cifrado del volumen EBS
- Formalizar protocolo de notificación previa para actividad administrativa

🔴 No Realizado

- Fuerza bruta
- Explotación destructiva
- Shell de atacante no autorizado
- Extracción de credenciales AWS
- Persistencia o ataque a infraestructura ajena

13. Conclusión Profesional

El laboratorio permitió comprobar de forma práctica que una instancia EC2 aparentemente sencilla puede presentar diferentes superficies de riesgo dependiendo de su configuración de red, autenticación y servicios internos.

El hallazgo de mayor prioridad fue la exposición pública del servicio SSH mediante TCP/22 desde 0.0.0.0/0. Aunque los mecanismos de autenticación impidieron que el intento controlado obtuviera acceso, mantener un servicio administrativo accesible desde cualquier dirección de Internet aumentaba innecesariamente la superficie de ataque; esta condición fue corregida restringiendo el origen a la IP administrativa autorizada mediante /32, con validación posterior de conectividad.

El segundo escenario, IMDSv2 como Optional, fue corregido estableciendo IMDSv2 como Required, validado con HTTP 401 ante una solicitud sin token. Adicionalmente, el análisis de una actividad administrativa inicialmente marcada como sospechosa permitió confirmar que se trataba de un falso positivo, sin indicadores de compromiso, aunque evidenció una deficiencia de procedimiento en la notificación previa al equipo de seguridad. La evaluación general identificó oportunidades adicionales de hardening: cifrado del volumen EBS, revisión de X11 forwarding y endurecimiento del directorio .ssh.

En términos generales, el laboratorio cerró en una condición considerablemente más segura que la configuración inicial, con los dos hallazgos críticos (SSH e IMDS) remediados y validados técnicamente, y con una lección operativa clara sobre la importancia de formalizar la comunicación de actividades administrativas.

Calificación	Nivel
Riesgo global antes del laboratorio	**MEDIO-ALTO** (SSH público, privilegios sudo, IMDSv2 opcional)
Riesgo global después de remediaciones	**BAJO** — SSH e IMDS remediados y validados
Situación IMDS	**CONTROLADA / REMEDIADA**
Situación SSH	**CONTROLADA / REMEDIADA**
Situación actividad administrativa	**FALSO POSITIVO** — protocolo de notificación pendiente de formalizar

14. Aprobación y Conformidad

El presente reporte certifica el cumplimiento del laboratorio de seguridad AWS DevSecOps sobre la instancia devsecops-lab, dentro del programa de Prácticas Profesionales en Ciberseguridad.

Jesús Alejandro Rodríguez Medina
Practicante de Ciberseguridad / DevSecOps

✔ LABORATORIO COMPLETADO